



BÁO CÁO KIỂM THỬ

Touch VN - Báo cáo kiểm thử và đánh giá chất lượng

Chức năng, API, hiệu năng, bảo mật OWASP Top 10:2025 và chuỗi cung ứng.

THÔNG TIN	NỘI DUNG
Phiên bản kiểm thử	Touch VN 1.1.0
Ngày xác nhận gần nhất	06/08/2026
Acceptance	22/22 PASS
Phạm vi	Baseline tự động; không thay thế pentest độc lập

Phạm vi: Tài liệu thuộc bộ hồ sơ tốt nghiệp Touch VN - sinh viên Nguyễn Phạm Tân, MSSV 24730064, phiên bản sản phẩm 1.1.0.

1. Tóm tắt kết quả

Chỉ số	Kết quả	Đánh giá
Acceptance tests	22/22	PASS
CVE đã biết	0 trong lần quét	PASS tại thời điểm quét
DAST	Không có lỗi chặn	PASS
Stress smoke	120 request / 12 worker / 0 lỗi	PASS
p95 lần đóng gói cuối	0,921 giây	Dưới ngưỡng 3 giây
Release	26.638.674 bytes / 183 mục	Toàn vẹn

Kết luận: Quality gate của phiên bản 1.1.0 đạt trong môi trường kiểm thử. Kết quả là baseline kỹ thuật của đồ án, không phải chứng nhận pentest hoặc SLA production.

2. Phạm vi và phương pháp

- Kiểm thử kho điểm đến, tìm kiếm, phân loại, đa ngôn ngữ và must-go.
- Kiểm thử planner AI, structured output, smart fallback và dự toán ngân sách.
- Kiểm thử vé, gateway ưu tiên, booking, chat, chi tiêu, offline và QR/AR.
- Kiểm thử session, JWT, CSRF, quyền admin, security headers, SQL injection và SSRF.
- Biên dịch Python, cú pháp JavaScript, Bandit SAST và static checks nội bộ.
- Xác minh requirements.lock có hash, SBOM CycloneDX và dependency scan.
- DAST trên web/API tạm thời và stress smoke đồng thời.

3. Môi trường kiểm thử

Thành phần	Cấu hình
Hệ điều hành	Windows - workspace local
Python	Python 3.11+ trong .envr dự án
Web/API	Flask test client và FastAPI/Starlette test client
Database	SQLite test database tách biệt theo ca
Công cụ	unittest, Bandit, pip-audit, DAST và stress script nội bộ
Dữ liệu	63 điểm đến, 34 tỉnh/thành, 8 nhóm, VI/EN/KO

4. Kết quả 22 ca kiểm thử chấp nhận

Mã	Cá kiểm thử	Minh chứng	Kết quả
01	Địa lý hiện hành	63 điểm, đủ 34 tỉnh/thành, 3 miền	PASS
02	Tìm kiếm kết hợp	region + province + category + q	PASS
03	Danh mục/must-go	8 nhóm và xếp hạng	PASS
04	Mô tả đa ngôn ngữ	63/63 có VI/EN/KO	PASS
05	Khóa UI	486 khóa đồng nhất	PASS
06	Planner fallback	Đúng ngày, người, ngân sách	PASS
07	Structured output	Output ánh xạ schema	PASS
08	Bốn loại vé	Máy bay, tàu, xe, vui chơi	PASS
09	Gateway vé	Provider ngoài được ưu tiên	PASS
10	Auth/CSRF/admin	Session và quyền ghi	PASS
11	Headers/ngôn ngữ	Security headers và persistence	PASS
12	Chat	Lịch sử và fallback	PASS
13	Chi tiêu nhóm	Trip/payer/category/members/note	PASS
14	Offline	JSON và GeoJSON tải được	PASS
15	Hiệu năng route	Dưới ngưỡng demo	PASS
16	API/access control	Route công khai/bảo vệ đúng	PASS
17	Production secret	Từ chối secret yếu	PASS
18	SSRF	Từ chối private-network target	PASS
19	SQL injection	Input không được diễn giải như SQL	PASS
20	Dependency pinning	Yêu cầu được pin	PASS
21	Phân loại tiện ích gần đây	Ăn uống, khách sạn, nhà thuốc, cửa hàng, chợ, siêu thị, bệnh viện, vui chơi	PASS
22	Giữ chỗ vé theo người dùng	Mã giữ chỗ, trạng thái, số tiền và lịch sử được lưu đúng	PASS

5. Kiểm thử hiệu năng

Stress smoke gửi 120 request với 12 worker vào các route đại diện. Lần chạy xác nhận ngày 06/08/2026 không ghi nhận lỗi và p95 khoảng 0,921 giây, thấp hơn ngưỡng 3 giây. Kết quả chỉ phản ánh máy local,

dữ liệu hiện tại và thời lượng smoke; không đại diện tải dài hạn, nhiều vùng mạng hoặc provider thương mại.

6. Đối chiếu OWASP Top 10:2025

Mã	Nhóm	Kiểm soát	Kết quả
A01	Access Control	Role/ownership, CSRF, SSRF, session reset, JWT revoke	Đạt baseline
A02	Misconfiguration	HTTPS/HSTS, tắt docs/debug/reload, headers	Đạt baseline
A03	Supply Chain	Hash lockfile, SBOM, pip-audit, loại .venv	Đạt baseline
A04	Cryptography	Password hash, aud/iss/jti, cookie, secret ngoài mã	Đạt baseline
A05	Injection	Binding, Pydantic, autoescape, URL validation	Đạt baseline
A06	Insecure Design	Limits, timeout, fallback, least privilege	Đạt baseline
A07	Authentication	session.clear, timeout, POST logout, rate limit	Đạt baseline
A08	Integrity	Structured output, server-side calculation, lock/SBOM	Đạt baseline
A09	Logging/Alerting	Audit HMAC, auth/admin/integration events	Đạt baseline
A10	Exceptions	Global handler, rollback, quota, timeout, fallback	Đạt baseline

7. Chuỗi cung ứng phần mềm

- requirements.lock pin dependency trực tiếp và gián tiếp, kèm SHA-256.
- Cài đặt production dùng pip --require-hashes.
- sbom.cdx.json ghi nhận thành phần theo CycloneDX.
- pip-audit đối chiếu advisory database tại thời điểm quét.
- ZIP release loại .venv, cache, database, log và secret.

8. Vấn đề còn mở và rủi ro tồn dư

Rủi ro	Tác động	Khuyến nghị trước thương mại
Chưa pentest độc lập	Có thể bỏ sót lỗ hổng logic/hạ tầng.	Pentest hộp đen và review cấu hình cloud.
SQLite một instance	Giới hạn ghi đồng thời và HA.	PostgreSQL/PostGIS và migration rõ ràng.
Provider demo/fallback	Không phản ánh tồn chỗ, giá, quota thật.	Hợp đồng provider, sandbox và test webhook.
AI chưa có eval chuyên gia	Lịch trình có thể chưa tối ưu thực tế.	Bộ eval, phản hồi người dùng và guardrail.
AR chưa native 3D	Trải nghiệm mới ở mức overlay.	SDK mobile, model 3D và geospatial anchors.

Rủi ro	Tác động	Khuyến nghị trước thương mại
Stress smoke ngắn	Không phát hiện memory leak/tải dài.	Soak test, load test và chaos test.

9. Kết luận kiểm thử

Phiên bản Touch VN 1.1.0 đạt tiêu chí nghiệm thu của đồ án và đủ điều kiện đóng gói bàn giao. Trước production thương mại cần cấu hình secret/HTTPS thật, tắt seed demo, thực hiện pentest độc lập, kiểm thử provider và bổ sung giám sát tập trung.